

01.REQUISITO FUNCIONAL “Gestiones” “Epicas”

ID:	EP-001
Nombre:	Gestión de Autenticación, Usuarios y Seguridad
Tipo	Requisito Funcional M-001acro / Épica
Módulo	Módulo de Seguridad y Usuarios
Actor principal	Administrador (Rol 3)
Actores secundarios	Técnico (Rol 1), Usuario Estándar (Cliente)
Prioridad	Alta
Estado	En Análisis / En Proceso
Versión	2.0
Autor	Equipo 2 QA
Fecha	23/07/2026
Objetivo del Negocio	Garantizar un acceso seguro, controlado y auditado a la plataforma Celuaccel mediante autenticación por tokens (JWT), control de sesiones por inactividad y gestión centralizada de roles y perfiles.
Descripción General	Módulo encargado del ciclo de vida de la sesión y perfil del usuario: inicio de sesión, registro, recuperación de contraseña, gestión de datos personales, control de inactividad a los 15 minutos, y asignación de roles y tipos de documentos.

Alcance	Incluye: • Autenticación mediante JWT con contraseñas encriptadas en bcrypt. • Control de inactividad automático (cierre de sesión tras 15 minutos). • Rate limiting en endpoints sensibles (/login, /registro, /forgot-password). • Control de acceso basado en roles para vistas y rutas. • Gestión de tipos de documentos.
	No incluye: • Autenticación por biometría ni inicios de sesión de terceros (Google, OAuth2).
Actores Involucrados	Administrador (Rol 3: acceso total), Técnico (Rol 1/3: operaciones de servicio), Cliente (acceso a perfil y catálogo público).
Reglas de Negocio ID Regla Justificación Prioridad	- RN-001 Las contraseñas deben encriptarse con bcrypt en la BD. Seguridad de datos sensibles. Alta. - RN-002 La sesión se destruye tras 15 minutos de inactividad. Prevenir accesos no autorizados. Alta. - RN-003 Limitar intentos de login fallidos (rate-limiting) Mitigar ataques de fuerza bruta.

	Alta. -RN-004 Correo y documento de identidad deben ser únicos .Mantener integridad de usuarios. Alta
Requisitos No Funcionales Asociados	RNF-001 (Seguridad JWT/Bcrypt), RNF-002 (Tiempo de respuesta de API < 2 segundos).
Subrequisitos Relacionados	RF-001 (Autenticación), RF-002 (Gestión de Perfil), RF-003 (Gestión de Roles).
Dependencias	Conexión a base de datos MySQL activa y middleware de autenticación (JWT) operativo.
Riesgos	Caída del servidor de base de datos que impida la validación de credenciales; exposición del token JWT en el lado del cliente.
Criterios Generales de Aceptación	1.El sistema debe mostrar un mensaje de error claro y denegar el acceso ante credenciales incorrectas. 2.El sistema debe redirigir a la pantalla de inicio de sesión automáticamente tras 15 minutos sin interacción del usuario.
Trazabilidad	Matriz General de Requisitos Celuacel -> EP-001.
Observaciones	Documentación basada en arquitectura Node.js/React validada vía Swagger UI.

02.REQUISITO FUNCIONAL “Gestiones” “Epicas”

ID:	EP-002
Nombre:	Gestión de Roles, Permisos y Accesos
Tipo	Requisito Funcional Macro / Épica
Módulo	Módulo de Seguridad y Administración
Actor principal	Administrador (Rol 3)
Actores secundarios	Técnico (Rol 1), Usuario Estándar (Cliente)
Prioridad	Alta
Estado	En Análisis / En Proceso
Versión	2.0
Autor	Equipo 2 QA
Fecha	23/07/2026
Objetivo del Negocio	Controlar de forma centralizada los niveles de acceso y privilegios en la plataforma Celuaccel, garantizando que cada tipo de usuario interactúe únicamente con las funcionalidades correspondientes a su perfil de negocio.
Descripción General	Módulo encargado de la administración de perfiles dentro del sistema: creación, edición y asignación de roles

	(Administrador,Técnico, Cliente) así como el control de acceso basado en roles (RBAC) sobre vistas, rutas del frontend y endpoints del backend.
Alcance	Incluye: • Asignación y cambio de rolas de usuario desde el panel administrativo. • Restricción de acceso en el cliente (React) mediante componentes protegidos por rol. • Validaciones de permisos en el backend mediante middlewares de autenticación y autorización JWT. • Gestión de catálogos parametricos asociados a os perfiles (tipos de documentos, estado de usuario).
	No incluye: •Delegación temporal de permisos entre usuarios. •Jerarquías dinámicas o creación personalizada de roles sin despliegue previo.
Actores Involucrados	Administrador (Rol 3): Acceso total; asigna roles, modifica permisos y gestiona usuarios del sistema,Técnico (Rol 1): Acceso restringido a módulos de servicio, órdenes de trabajo y gestión operativa,Cliente(Rol 2): Acceso restringido a su perfil personal, solicitudes y catálogo público de productos/servicios.
Reglas de Negocio ID	-RN-005 Todo usuario recin registrado debe tener asignado por defecto el rol Cliente

Regla Justificación Prioridad	Control de seguridad inicial y prevención de elevación de privilegios. Alta -RN-006 Solo el perfil Administrador(Rol 3) puede alterar el rol de otros usuarios registrados. Proteger las funciones críticas del negocio de modificaciones no autorizadas. Alta -RN-007 Las peticiones a rutas protegidas sin los permisos requeridos deben retornar un código http 403(fordbidden).
Requisitos No Funcionales Asociados	RNF-001 (Seguridad y encriptación de datos) RNF-002 (Tiempo de respuesta de API < 2 segundos).
Subrequisitos Relacionados	RF-003 (Asignación y Cambio de Roles) RF-004 (Control de Acceso a Rutas Protegidas).
Dependencias	Módulo de Autenticación y Seguridad (EP-001) operativo, middleware JWT activo.
Riesgos	Inconsistencia en la expiración del token JWT que permita navegación con permisos desactualizados tras un cambio de rol.

Criterios Generales de Aceptación	1. El sistema debe bloquear inmediatamente el acceso a usuarios que intenten ingresar a rutas no autorizadas. 2. La asignación de un nuevo rol debe reflejarse en las peticiones posteriores tras la actualización del token/sesión. 2.El sistema debe redirigir a la pantalla de inicio de sesión automáticamente tras 15 minutos sin interacción del usuario.
Trazabilidad	Matriz General de Requisitos Celuaccel -> EP-002 .
Observaciones	Documentación basada en arquitectura Node.js/React validada vía Swagger UI.

PLANTILLA REQUISITO FUNCIONAL (RF)

ID:	RF-001
Nombre:	Autenticación e Inicio de Sesión de Usuarios
Actor principal:	Usuario (Administrador, Técnico, Cliente)
Actores secundarios:	Servidor Backend (Node.js / Express)
Prioridad:	Alta

Descripción:	El sistema debe permitir a los usuarios registrados (Administrador, Técnico o Cliente) iniciar sesión mediante sus credenciales (correo/documento y contraseña). Tras la validación, el backend generará un token JWT para gestionar la sesión activa, aplicando controles de seguridad como encriptación en bcrypt, límite de intentos y cierre automático por inactividad.
Entradas:	1. Tipo/Número de Documento o Correo Electrónico. 2. Contraseña en texto plano.
Precondiciones:	1. El usuario debe estar previamente registrado en la base de datos MySQL. 2. La base de datos MySQL y el servicio de backend deben estar operativos. 3. Las contraseñas en la base de datos deben estar encriptadas con bcrypt (RN-001).
Postcondiciones:	1. Generación y retorno de un token de autenticación (JWT) al cliente. 2. Redirección del usuario a la vista correspondiente según su rol (Administrador, Técnico o Cliente). 3. Inicio del temporizador de control de inactividad (15 minutos).
Flujo principal:	1. El usuario ingresa sus credenciales (documento y contraseña) en el formulario de inicio de sesión. 2. El usuario hace clic en el botón "Iniciar

	Sesión". 3. El sistema valida la existencia del usuario en la base de datos. 4. El sistema compara la contraseña ingresada con el hash almacenado utilizando bcrypt. 5. El sistema genera un token JWT con la información del rol del usuario y lo envía al cliente. 6. El sistema redirige al usuario a la interfaz de inicio según su perfil y activa el control de inactividad de 15 minutos.
Flujos alternativos:	1. El usuario ingresa sus credenciales (documento y contraseña) en el formulario de inicio de sesión. 2. El usuario hace clic en el botón "Iniciar Sesión". 3. El sistema valida la existencia del usuario en la base de datos. 4. El sistema compara la contraseña ingresada con el hash almacenado utilizando bcrypt. 5. El sistema genera un token JWT con la información del rol del usuario y lo envía al cliente. 6. El sistema redirige al usuario a la interfaz de inicio según su perfil y activa el control de inactividad de 15 minutos.
Salidas:	1. Mensaje de éxito e inicio de sesión con token JWT almacenado. 2. Mensajes de error en caso de credenciales inválidas o bloqueo de tasa (rate limiting).

Criterios de aceptación:	1. El sistema debe mostrar un mensaje de error claro y denegar el acceso ante credenciales incorrectas. 2. El sistema debe redirigir a la pantalla de inicio de sesión automáticamente tras 15 minutos sin interacción del usuario. 3. El tiempo de respuesta del backend para la validación no debe superar los 2 segundos.
Reglas de negocio asociadas:	- RN-001: Las contraseñas deben encriptarse con bcrypt en la BD. - RN-002: La sesión se destruye tras 15 minutos de inactividad. - RN-003: Limitar intentos de login fallidos (rate-limiting). - RN-004: Correo y documento de identidad deben ser únicos.
RNF asociados:	- RNF-001: Seguridad JWT/Bcrypt. - RNF-002: Tiempo de respuesta de API < 2 segundos.
Casos de prueba asociados:	
Observaciones:	Documentación basada en arquitectura Node.js/Express y React, validada vía Swagger UI.

Historial de cambios

Versión	Fecha	Autor	Descripción
1.0	20-07-2025	Anderson Joya	Creación del requisito

2.0	24-07-2025	Anderson Joya	Corrección de requisitos

Aprobaciones

Rol	Nombre	Firma	Fecha
Cliente			
Product Owner			
auditor			